

TECHNICAL SECURITY SPECIFICATIONS FOR
VMWARE VCENTER 6.X AND 7.0

AUTHOR(S) : Roland Wittmann/Mangesh Kulkarni
DOCUMENT NUMBER : MSP-GAD-0278
VERSION : 2.0
STATUS : Final
SOURCE : Atos
DOCUMENT DATE : 10 November 2020
NUMBER OF PAGES : 15

OWNER : Ritesh Sinha

Role	Signature
Document Owner	28-12-2020  Ritesh Sinha Sinha, Ritesh Global Service Architect Signed by: Ritesh Sinha
Reviewer	18/12/2020   Magdalena Zabrocka Global Operation Security Compliance Officer Signed by: Magdalena Gondek
Quality Assurance Function	18/12/2020  Approved Magdalena Gondek IDM Documentation Controller Signed by: Magdalena Gondek
Senior Manager	28/12/2020  Approved Dorin Vlas Head of Risk Management and Control Fra... Signed by: Dorin Vlas

Contents

1	General Information	6
1.1	Purpose	6
1.2	Audience	6
1.3	Scope	6
1.4	Implementation of Measures.....	6
1.5	Documentation maintenance and distribution.....	6
1.6	Related documents	7
2	Introduction	8
2.1	Risk Classification.....	8
2.2	Deviations	8
3	Description of Measures	9
3.1	User Management and Access Control.....	9
4	Related measures	14
Appendix A	Checklist	15

List of changes

version	Date	Description	Author(s)
1.0	01-08-2018	Initial Release Quality Check, Template Update	Roland Wittmann Bartosz Dalak
1.1	10-30-2019	Review for changes	Roland Wittmann
1.2	13-12-2019	Security Review	M. Zabrocka
1.3	27-01-2020	New measure number VE00006 assigned for duplicated VE00004 "Restrict Port-Level Configuration Overrides On VDS"	M. Zabrocka
1.4	28-05-2020	Updated with VMware vSphere 6.7 and 7.0 Version	Mangesh Kulkarni
1.5	05-06-2020	Updated Template and Quality Check	Ankita Shrivastava
1.6	05-06-2020	Reviewed and make changes as per MZ and RN comments	Ritesh Sinha
1.7	25-06-2020	Security review	R. Nair, M. Zabrocka
1.8	28-06-2020	Baseline references, dates and some background description added	Baig, Kashif
1.9	01-07-2020	Another Security/Quality review	M. Zabrocka
1.10	08-07-2020	Updated Measure VV00005 with Disable TLSv1.0, TLSv1.1 and enabling TLSv1.2 Updated Measure VV00006 with Baseline Reference of 2.1.1 Moved VV00005 and VV00006 in User Management and Access Control section from Related measures	Nizamuddin Shaikh
1.11	17-07-2020	Next Security Review	M. Zabrocka
1.12	12-08-2020	Cloud Review	P. Limonard
1.13	10-11-2020	Measure ID prefix restored, Target readers added	M. Zabrocka
2.0	10-11-2020	Final Quality assurance	M. Zabrocka M. Gondek

Target readers, communication method

Target group	Distribution / publication method
Designers, architects and administrators tasked with validation and implementation of the security baselines.	The TSS documents are published by Atos Risk, Audit & Compliance Governance (RACG) on SharePoint https://sp2013.myatos.net/ms/gd/gadp/TSSD/

Terms and abbreviations

Terms / Abbreviations	Description
ART	Atos Risk Tool
ATLM	Atos Technology Lifecycle Management
BDS	Atos Big Data & Security Division
IDM	Atos Infrastructure & Data Management Division
ITCF	IT Control Framework
GOSCO	Global Operation Security Compliance Officer
RAGC	Risk, Audit and Compliance Governance
RAF	Risk Acceptance Form
RFC	Request for Comments
SLA	Service Level Agreements
TSS(D)	Technical Security Specifications (Document)

1 General Information

1.1 Purpose

A Technical Security Specification (TSS) is the document that can be seen as a result of the translation of the Atos IT Security Controls as described in the Security Baselines to specific Technical Security Controls.

This document holds the definitions of the security measures corresponding to the Technical Security Controls for a specific device or software area. The document contains details about how to configure the target devices and software and what needs to be validated for checking the compliancy to that measure.

The document also details on the risk classification and the data and data sources required for an IT Security Control.

1.2 Audience

This document is intended for designers, architects and administrators tasked with validation and implementation of the security baselines as per IT Security Control Framework.

The document assumes that the reader has reasonable understanding of the Security Compliance Process as well as familiarity with the devices/software mentioned in this document.

1.3 Scope

The scope of this Technical Security Specification covers the following:

- ▶ VMware vCenter Server 6.7
- ▶ VMware VCSA 7.0

The following areas are explicitly out of scope:

- ▶ All other VMware released SW products
- ▶ Other versions of VMware ESXi
- ▶ ESXi 6.7

1.4 Implementation of Measures

The implementation of the TSS measures is mandatory for all target devices and software mentioned in the scope. In case of implementation in existing environments, TSS measures must be tested first in pre-production test environments following applicable change management processes before implementation in production.

Some of the measures in this document may affect compliance to industry specific regulations. In this case the security officer must approve the implementation or create an exception.



All exceptions to measures mandated by this document must be registered in the Atos Risk Tool (ART) and must be agreed by the Client Security Manager and the Customer.

1.5 Documentation maintenance and distribution

The TSS document, when approved, published and validated, becomes procedural to all referenced systems, services, applications or processes managed by Atos Infrastructure & Managed Data (I&DM) following a 120 days grace period, during which an analysis of gaps, documentation of exceptions, and a plan to bring non-compliant systems into compliance must be developed. The maintenance of the document is performed by the Global Service Architect. TSS documents will be reviewed on an annual basis, unless technical or business requirements dictate updating sooner.

1.6 Related documents

This document is a subset of Atos Technology Lifecycle Management (ATLM) artefacts. Related documents are captured in below table.

Reference	Document Name
MSM-GSS-0001	Security Management Baseline
MSM-GSS-0002	Logical Security Baseline
MSM-GSS-0006	Server Security Baseline
MSM-GSS-0003	Network Device Security Baseline
ASM-SEC-0006	Password Policy
ASM-SEC-0001	Atos Information Security Policy
TSS Measure IDs	Name conventions and allocated Measure ID's

Several vendor best practice documentations have been used in this TSS as per next table.

This document is a subset of VMWare Inc., vendor security baseline related documents are captured below in Table

Vendor	Document Name / Reference
VMware	https://docs.vmware.com/en/VMware-vSphere/6.7/vsphere-esxi-vcenter-server-67-security-guide.pdf
VMware	https://docs.vmware.com/en/VMware-vSphere/6.7/com.vmware.vsphere.security.doc/GUID-BE5FF51E-2C94-40E7-94F2-FE2108E586F1.html
VMware	https://kb.vmware.com/s/article/2147469
VMware	https://docs.vmware.com/en/VMware-vSphere/6.7/com.vmware.vsphere.security.doc/GUID-412EF981-D4F1-430B-9D09-A4679C2D04E7.html
VMware	https://docs.vmware.com/en/VMware-vSphere/7.0/rn/vsphere-esxi-vcenter-server-70-release-notes.html
VMware	https://docs.vmware.com/en/VMware-vSphere/7.0/com.vmware.vcenter.upgrade.doc/GUID-752FCA83-1A9B-499E-9C65-D5625351C0B5.html
VMware	https://docs.vmware.com/en/VMware-vSphere/7.0/vsphere-esxi-vcenter-server-70-security-guide.pdf

2 Introduction

The 'Technical Security Specification for VMware vCenter Server 6.x / 7.0' is a mandatory supplement to the existing Atos Security Policy and IT Security Controls. Its purpose is to increase security for IT systems and it must be implemented for all Atos managed devices. The measures and their priorities described here may be tightened and supplemented as necessary.

The TSS documents are published by Atos Risk, Audit & Compliance Governance (RACG). The TSS itself is coordinated with reviewers from the Global Security Services and all relevant Atos Global Delivery units. It aims at providing sufficient detail to allow a qualified administrator to implement all measures.

To assist in documentation, a checklist for the manual validation process has been prepared as part of this TSS in appendix A.

Further assurance about the compliance of a device or software to the Atos IT Security Controls can be gained via a Scan on Demand as part of the Vulnerability Management Service offered Atos Big Data & Security (BD&S).

2.1 Risk Classification

Each confirmed measure is assigned a risk level (Critical, Moderate, or Low) corresponding to its potential impact on the security of Atos service delivery and devices/software in scope.

CRITICAL

A security control is critical if it can be exploited by a remote attacker to gain access to the system, data or functionality when not implemented. All critical controls must be implemented before the equipment is installed in a production environment.

MODERATE

A security control is rated moderate if it can compromise data or functionality on the network equipment only if some other condition is met (e.g. a module or a user within a role is required). Moderate issue security bulletins typically include recommended actions to resolve the issue.

LOW

A security control is rated low if it is very difficult to exploit from outside or has a limited potential impact.

2.2 Deviations

Deviations to the measures must be corrected according to customer agreed Service Level Agreements (SLA). Atos will use default resolution targets for correcting the deviations that must be confirmed or changed by each customer.

Because correcting a deviation may impact the customer's business process, the analyst must decide whether the customer should be consulted. If the customer does not agree with correcting a deviation because doing so will negatively impact his business, a Risk Acceptance Form (RAF) must be signed and handed over to formally transfer the associated risks to the customer. Atos will retain the right to accept or challenge the customer exception request.

3 Description of Measures

All measures in this document are categorized as MANDATORY. This categorization means that implementation is absolutely required. Exceptions other than those explicitly declared inside a measure require approval by DBS and GADP.

The key words 'MUST', 'MUST NOT', 'REQUIRED', 'SHALL', 'SHALL NOT', 'SHOULD', 'SHOULD NOT', 'RECOMMENDED', 'MAY', and 'OPTIONAL' in this document are to be interpreted as described in RFC 2119 (<https://www.ietf.org/rfc/rfc2119.txt>).

All measures are grouped into specific areas. The specific areas are chosen to combine measures where the IT Security Control can be divided into multiple measures, e.g. 'Updates and Patches', 'User Management and Access Control' and 'Protocols and Services'.

3.1 User Management and Access Control

Measure ID	1VV00001
Measure Title	Securely Configure The ' <i>Forged Transmits</i> ' Policy Is Set to Reject
Classification	LOW
Baseline Reference	MSM-GSS-0003 -Security Management Baseline
Background	Forged Transmit Accept setting to help the deployment of VPN use case opens a security hole where the compromised virtual machine can perform spoofing attacks
Measure	Ensure That The ' <i>Forged Transmits</i> ' Policy Is Set To Reject on VDS
Implementation	From the vSphere Web Client select the host and click '<i>Manage</i>' -> '<i>Networking</i>' -> '<i>Virtual Switches</i>'. For each virtual switch and for each port group within that virtual switch, click edit. Go to '<i>Security</i>' and verify that '<i>Forged Transmits</i>' is set to '<i>Reject</i>'. From vSphere Web Client, for each port group within each distributed switch go to '<i>Manage</i>' -> '<i>Settings</i>' -> '<i>Policies</i>' and click 'Edit'. Go to '<i>Security</i>' and set the '<i>Forged transmits</i>' policy to '<i>Reject</i>'. http://kb.vmware.com/kb/2017193 http://kb.vmware.com/kb/2047822 http://pubs.vmware.com/vsphere-60/topic/com.vmware.vsphere.security.doc/GUID-FA661AE0-C0B5-4522-951D-A3790DBE70B4.html https://docs.vmware.com/en/VMware-vSphere/7.0/vsphere-esxi-vcenter-server-70-security-guide.pdf
Exception	None
First Appearance	31/08/2017

Measure ID	1VV00002
Measure Title	Securely Set The ' <i>Media Access Control (MAC)</i> ' address Policy To Reject on VDS
Classification	LOW
Baseline Reference	No Reference Baselines
Background	When the Mac address changes option is set to Reject, ESXi does not honor requests to change the effective MAC address to a different address than the initial MAC address
Measure	Ensure That The ' <i>Media Access Control (MAC)</i> ' address Policy Is Set To Reject on each distributed virtual port group
Implementation	From the vSphere web client select the tab 'Networking'. For each distributed virtual switch and for each distributed virtual port group within that virtual switch, click 'Edit Settings'. Go to 'Security' and verify that 'MAC address changes' is set to 'Reject'. VMware-vSphere 6.0 VMware-vSphere 6.5 VMware-vSphere 6.7 VMware-vSphere 7.0
Exception	None
First Appearance	31/08/2017

Measure ID	1VV00003
Measure Title	Ensure That The ' <i>Promiscuous Mode</i> ' Policy Is Set To Reject on VDS
Classification	LOW
Baseline Reference	No reference Baselines
Background	Although promiscuous mode can be useful for tracking network activity, it is an insecure mode of operation, because any adapter in promiscuous mode has access to the packets even if some of the packets are received only by a particular network adapter.
Measure	Ensure that the ' <i>Promiscuous Mode</i> ' policy is set to reject
Implementation	From the vSphere web client select the tab 'Networking'. For each distributed virtual switch and for each distributed virtual port group within that virtual switch, click 'Edit Settings'. Go to 'Security' and verify that 'Promiscuous Mode' is set to 'Reject'. VMware-vSphere 6.0 VMware-vSphere 6.5 VMware-vSphere 6.7 VMware-vSphere 7.0
Exception	None
First Appearance	31/08/2017

Measure ID	1VV00004
Measure Title	Restrict Port-Level Configuration Overrides On VDS
Classification	LOW
Baseline Reference	No Reference Baselines
Background	This allows for different security settings to be set from what is established at the Port-Group level. There are cases where particular VMs require unique configurations, but this should be monitored so it is only used when authorized. If overrides are not monitored, anyone who gains access to a VM with a less secure VDS configuration could surreptitiously exploit that broader access. Note: By default it is disabled
Measure	Set vNetwork.restrict-port-level-overrides Parameter
Implementation	From vSphere Web Client, for each portgroup within each distributed switch right click on the distributed portgroup' -> 'Settings' -> 'Advanced'. Verify that all 'Override port policies' are 'Disabled'. VMware-vSphere 6.0 VMware-vSphere 6.5 VMware-vSphere 6.7 VMware-vSphere 7.0
Exception	None
First Appearance	31/08/2017

Measure ID	2VV00005
Measure Title	Disable TLSv1.0 and TLSv1.1
Classification	MODERATE
Baseline Reference	https://kb.vmware.com/s/article/2147469
Background	TLS v 1.0, 1.1 are insecure and need to be disabled.
Measure	Disable SSLv3, TLSv1.0 and TLSv1.1
Implementation	TLSv1.0 and TLSv1.1 are insecure and should not be used anymore Default Configuration has TLS 1.0 and TLS 1.1 enabled for some components: <pre> ===== Scanning vCenter Server TLS endpoints ===== +-----+-----+-----+ Service Name TLS Endpoint Port TLS Version(s) +-----+-----+-----+ vmware-rbd-watchdog NOT RUNNING vmcam NOT RUNNING vmware-rhttpproxy 443 TLSv1.0 TLSv1.1 TLSv1.2 rsyslog 1514 TLSv1.0 TLSv1.1 TLSv1.2 vami-lighttpd 5480 TLSv1.0 TLSv1.1 TLSv1.2 vmware-updatemgr 8084 TLSv1.0 TLSv1.1 TLSv1.2 vmware-updatemgr 9087 TLSv1.0 TLSv1.1 TLSv1.2 vsphere-client 9443 TLSv1.1 TLSv1.2 vsphere-ui 5443 TLSv1.1 TLSv1.2 </pre>

	<pre> +-----+-----+-----+ Remediation: Follow the step by step instruction for both vCenter Versions (Windows based and Appliance) from https://kb.vmware.com/s/article/2147469 : Disabling TLSv1.0 , TLSv1.1 and enabling TLSv1.2 will be a multi-phase process in a vSphere environment: 1. Install the TLS Reconfigurator Utility on the vCenter Server and Platform Services controller; if the Platform Services Controller is embedded on the vCenter Server, users only need to install the utility on vCenter Server. 2. Disable vCenter Server's and vSphere Update Manager's use of TLSv1.0, TLSv1.1 and enable the use of TLSv1.2. 3. The ESXi hosts managed by the vCenter Server will then be updated to disable the use of TLSv1.0, TLSv1.1 and enable the use of TLSv1.2 either by a per-host or per-cluster level modification 4. The Platform Services Controller would be updated to disable the use of TLSv1.0, TLSv1.1 and enable the use of TLSv1.2. After disabling the settings should look like: ===== Scanning vCenter Server TLS endpoints ===== +-----+-----+-----+ Service Name TLS Endpoint Port TLS Version(s) +-----+-----+-----+ vmware-rbd-watchdog NOT RUNNING vami-lighttpd 5480 TLSv1.2 vmcam NOT RUNNING vmware-rhttpproxy 443 TLSv1.2 rsyslog 1514 TLSv1.2 vmware-updatemgr 8084 TLSv1.2 vmware-updatemgr 9087 TLSv1.2 vsphere-client 9443 TLSv1.2 vsphere-ui 5443 TLSv1.2 +-----+-----+-----+ </pre>
Exception	If there are Plugins which are not yet TLS1.2 capable an exception must be raised by the default exception process
First Appearance	08-11-2017

Measure ID	3VV00006
Measure Title	Set Admin account policy
Classification	CRITICAL
Baseline Reference	See ASM-SEC-0006 (2.1.4) (2.1.1) and MSM-GSS-0002 (2.1.25)
Background	The vCenter Server 6.x / 7.0 appliance (working as vCenter or PSC) has a root account which does not follow the Atos policy by default. defined in Atos Documentation: See ASM-SEC-0006 (2.1.4)
Measure	Set the password policy for the admin account
Implementation	1. Connect to your vCenter Server 6.x / 7.0 appliance on port 5480: <a href="https://<fqdn>:5480">https://<fqdn>:5480 and login 2. Select '<i>Administration</i>' and set the Password Ageing for the root account to 90 days. 3. It is strongly recommended to use the option to send an email shortly before the password expires. If the password has expired please follow: https://kb.vmware.com/s/article/2147144 and https://kb.vmware.com/s/article/67414
Exception	None
First Appearance	08-11-2017

4 Related measures

The following measures cannot be tested by automated tooling, but are necessary to be implemented for the systems in scope.

Appendix A Checklist

Device Name	
-------------	--

Measure ID	Measure title	Alcatraz	Checked
1VV00001	Securely Configure The ' <i>Forged Transmits</i> ' Policy Is Set To Reject	NO	
1VV00002	Securely Set The ' <i>Media Access Control (MAC)</i> ' address Policy To Reject on VDS	NO	
1VV00003	Ensure That The ' <i>Promiscuous Mode</i> ' Policy Is Set to Reject on VDS	NO	
1VV00004	Restrict Port-Level Configuration Overrides On VDS	NO	
2VV00005	Disable TLSv1.0, TLSv1.1	NO	
3VV00006	Set Admin account policy	NO	